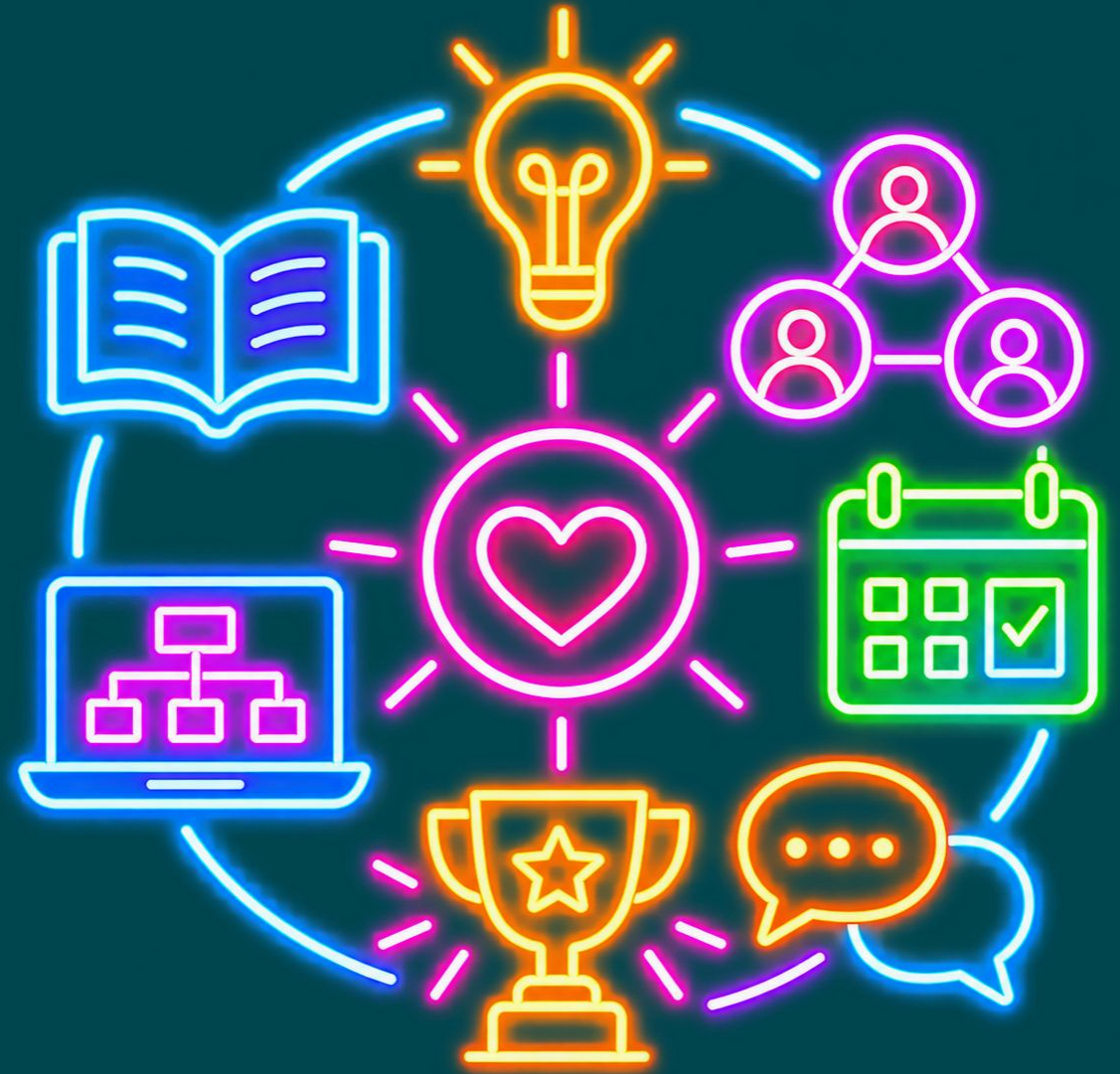




Become a Solution Architect

Enhance your Technical and Behavioural Skills

What did
you enjoy
most about
BeSA?





Week 6 - Agenda

Topic	Duration	Presenter
Technical Topic AI Governance on AWS	50 Mins	Ashish & Kanti
Behavioural Topic From Workshop to Action	30 Mins	Jeff & Aanchal
Workshop Walkthrough AI Governance on AWS	30 Mins	Ravali

BeSA Community Volunteers



Ashok



Athira



Choisel



Debanjan



Denise



Douglas



Elena



Harini



Linus



Logeshwari



Pawan



Ravi



Revanth



Reynaldo



Rishi



Sabarish



Sanjeev M



Shravanth



Silvestre



Steve



Vijaya





AI Governance on AWS



A city is not governed by stopping people from building.
It is governed by allowing activity within defined boundaries.

What is Governance?

Governance is the set of policies, rules, or frameworks that a company uses to achieve its business goals.



City Governance



Policies

Laws and building codes define what is allowed.

Example: A building cannot exceed the permitted height in a protected area.



Approvals

Certain activities require authorization before proceeding.

Example: A developer needs planning permission before constructing a new building.



Guardrails

Safety barriers prevent dangerous activity.

Example: Barriers stop pedestrians from entering a restricted construction zone.



Evaluation

Buildings and infrastructure are inspected to ensure they meet required standards.

Example: A new building undergoes a safety inspection before opening.



Oversight

Authorities monitor operations and intervene when required.

Example: Traffic-management teams monitor roads and respond to incidents.

AI Governance

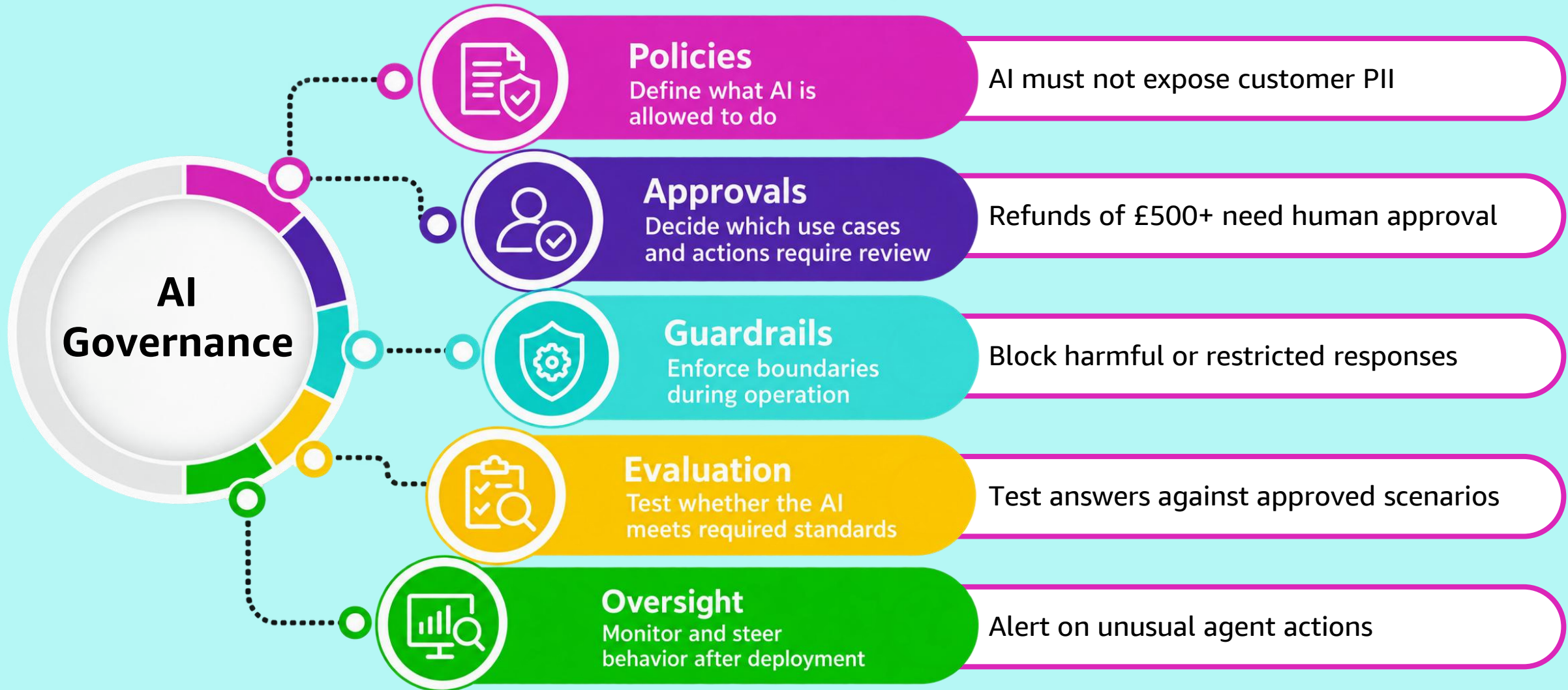
AI governance is how an organization decides which AI it will build or use, under what rules and controls, who is accountable, and how it continuously proves those systems remain lawful, ethical, and fit for purpose.



What changes with AI?



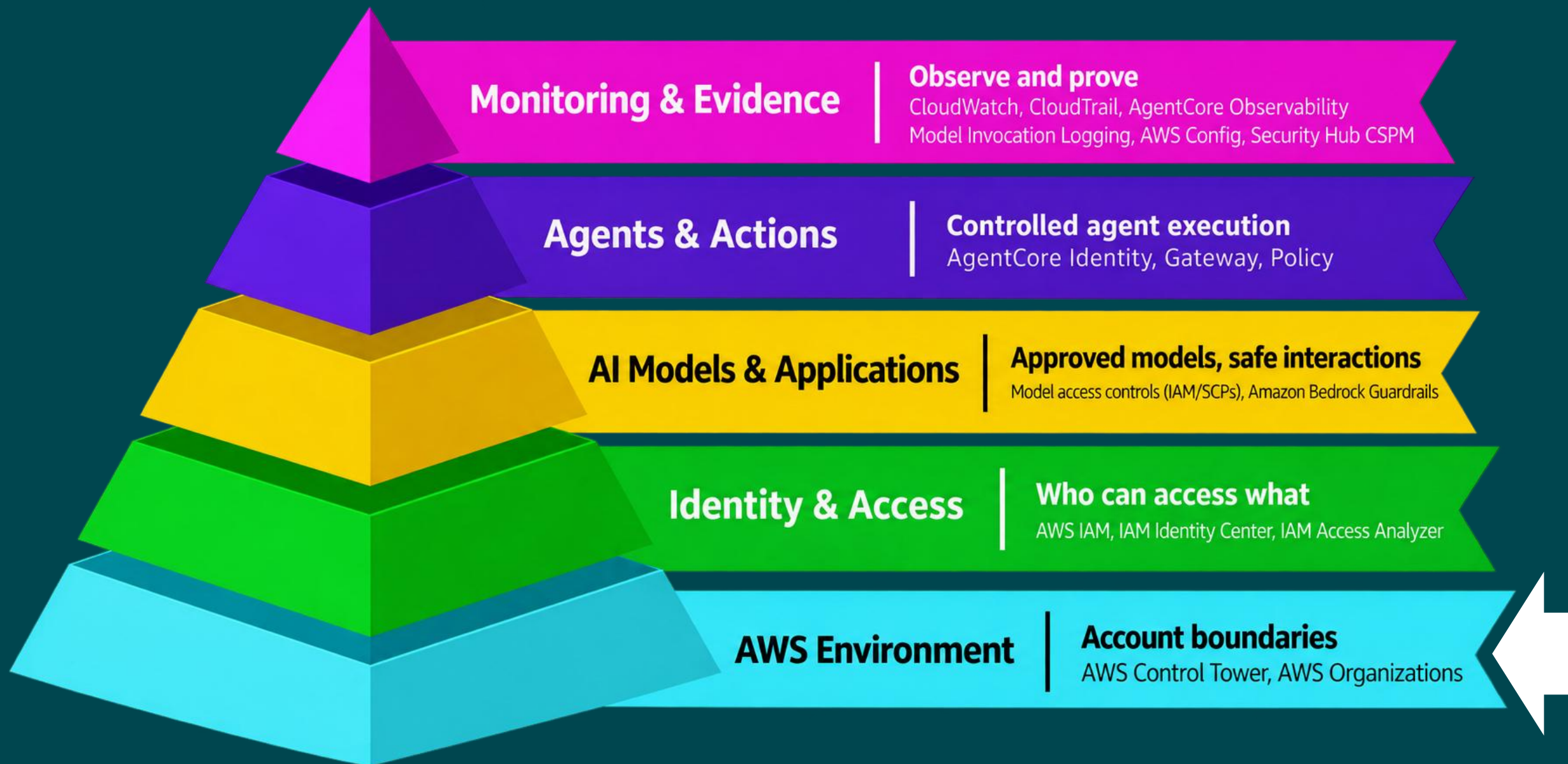
AI Governance





AI Governance at AWS

AI Governance in AWS

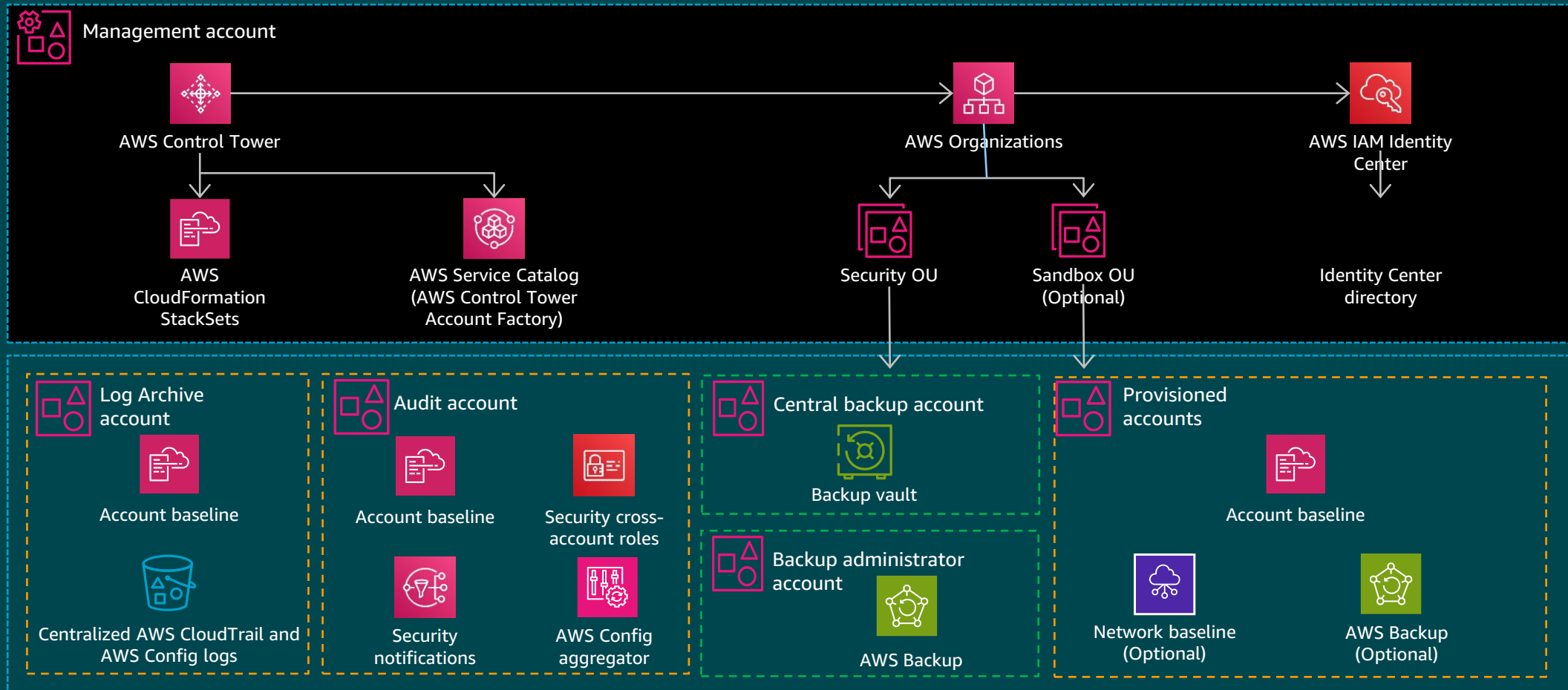




AWS
Environment

AI Governance Starts Before The AI Model Or Agent

- **AWS Control Tower** helps set up and govern a **multi-account AWS environment** using a landing zone and integrates capabilities from services such as **AWS Organizations** and **IAM Identity Center**.



How AWS Control Tower Controls Work



Preventive

Stops disallowed actions from happening

Implemented with



SCPs



RCPs

Example

Block users from performing a prohibited action.



Detective

Detects non-compliant resources after deployment

Implemented with



AWS Config Rules

Example

Detect that an EBS volume is not encrypted.



Proactive

Checks resources before they are provisioned

Implemented with



AWS CloudFormation Hooks

Example

Stop a non-compliant CloudFormation resource before it is created.

How Do We Know Resources Stay Compliant After Deployment?



The Problem



Resources keep changing

Teams update, modify, or delete resources after deployment.



Misconfigurations can appear

A resource that was compliant can become non-compliant later.



We need visibility and evidence

To meet governance, security, and audit requirements.



AWS Config Solves This

Provides continuous visibility into resource configuration and compliance.



Record

Captures configuration changes to AWS resources.



Track

Maintains configuration history over time.



Evaluate

Checks resources against AWS Config Rules.



Detect

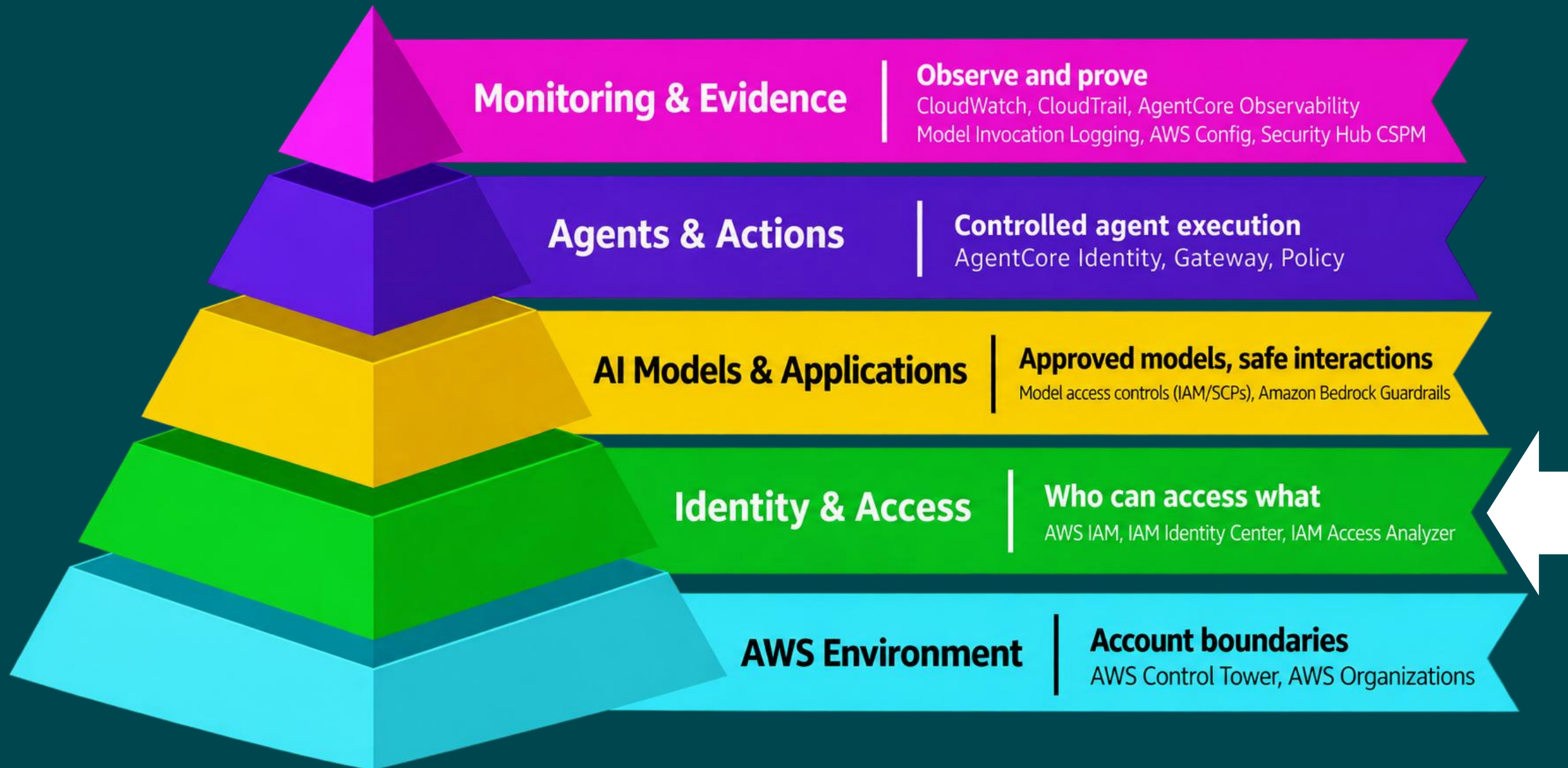
Identifies resources that become non-compliant.



Provide evidence

Supports governance, audit, and troubleshooting.

AI Governance in AWS

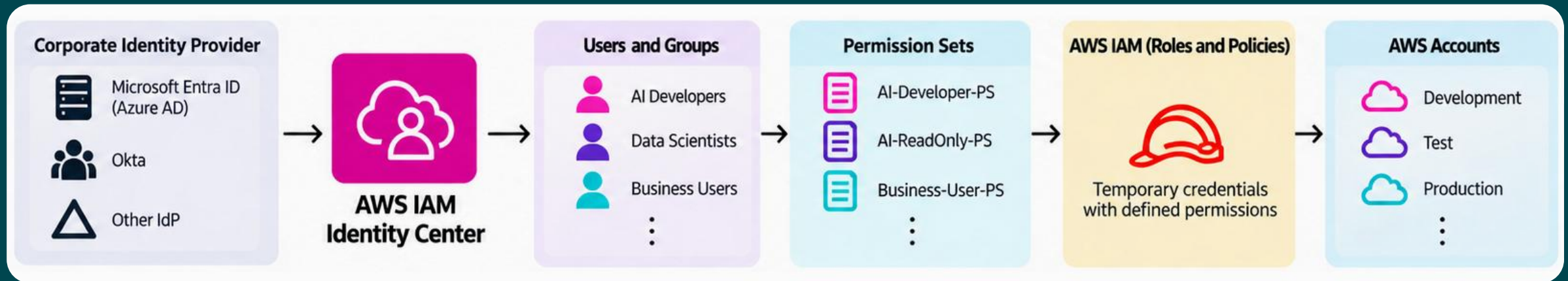




Identity
&
Access

How Do People Securely Access the AI Environment?

- IAM Identity Center centralizes workforce access across AWS accounts, while permission sets define the level of access users and groups receive in each account.



Example: AI Developer Access

An AI developer can access the development environment to build and test, but not the production environment.



How Do AI Workloads Securely Access AWS Resources?

- An AI workload needs access to data, APIs, models, and secrets — but only the resources required for its job.

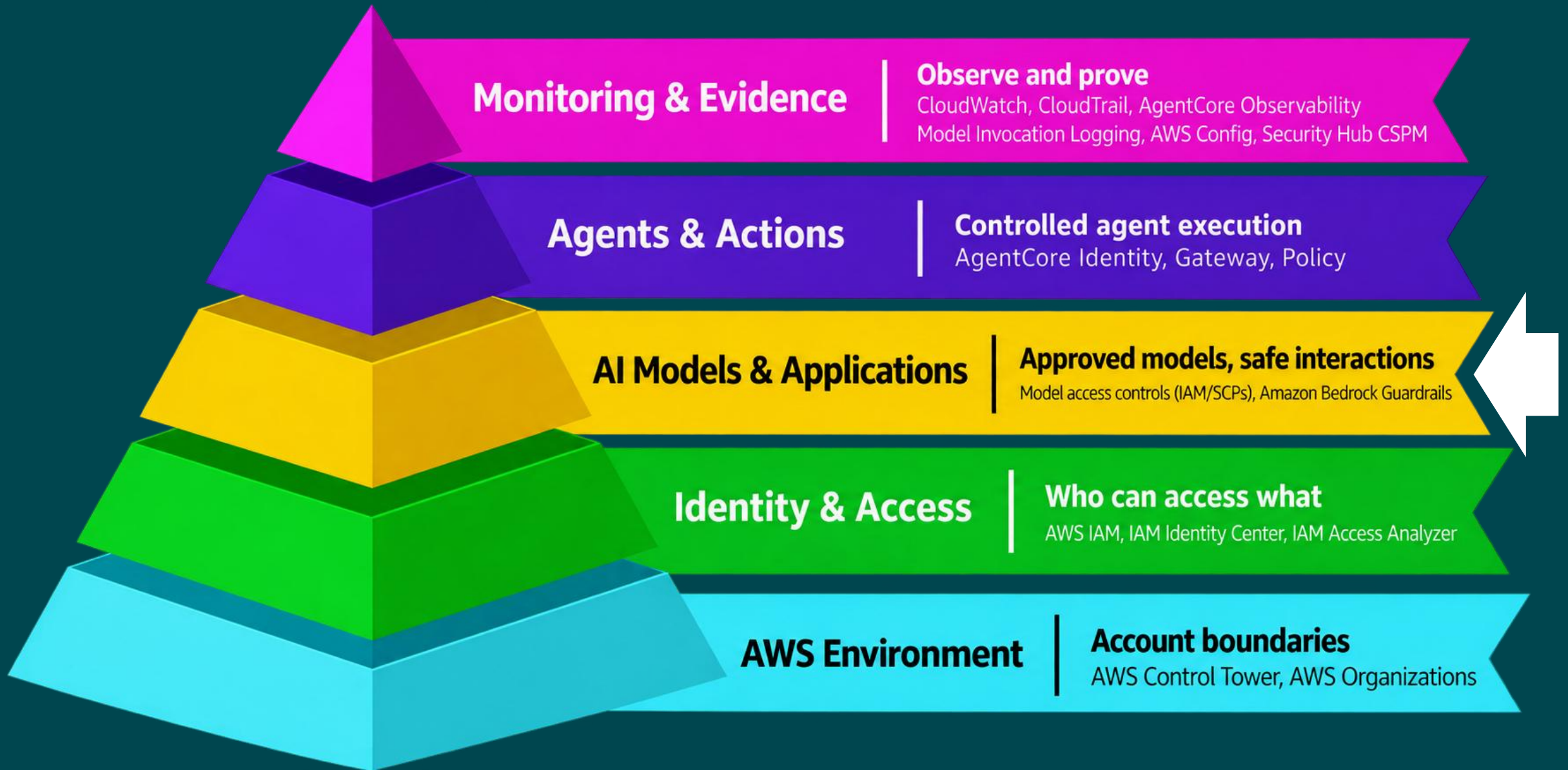
Business Need	AWS Capability
Give the workload an identity	IAM Role
Define what it can access	IAM Policies
Avoid embedded long-term credentials	Temporary credentials / AWS STS
Retrieve application secrets securely	AWS Secrets Manager
Protect encryption keys and encrypted data	AWS KMS

How Do We Know Access Has Become Too Broad?

- Least privilege is not a one-time configuration. Access must be continuously reviewed and refined.
- IAM Access Analyzer

Governance Question	IAM Access Analyzer Capability
Who outside my boundary can access this?	External access analysis
Who inside my organization can access this?	Internal access analysis
Which permissions are no longer being used?	Unused access analysis
Is this IAM policy too permissive or invalid?	Policy validation / custom policy checks
Can permissions be reduced based on actual usage?	Policy generation using CloudTrail activity

AI Governance in AWS





AI Models & Applications

Which Model Should We Choose?

- Discover → Assess → Test → Approve → Enforce

Step	What to Check	AWS Support
Discover	Which models are available?	Amazon Bedrock Model Catalog
Assess	Provider, Region, terms, lifecycle status	Model details / lifecycle state
Test	Does it meet the business use case?	Bedrock evaluations / test prompts
Approve	Is it allowed for this application?	Internal approved model list
Enforce	Can only approved models be invoked?	IAM policies / SCPs / bedrock:InvokeModel

All serverless Bedrock models are now enabled in every account by default.
The Enforce step is what limits which models can actually be used.

How Do We Ensure Developers Use Only Approved Models?

- Model approval is a business decision. IAM and SCPs turn that decision into enforcement.

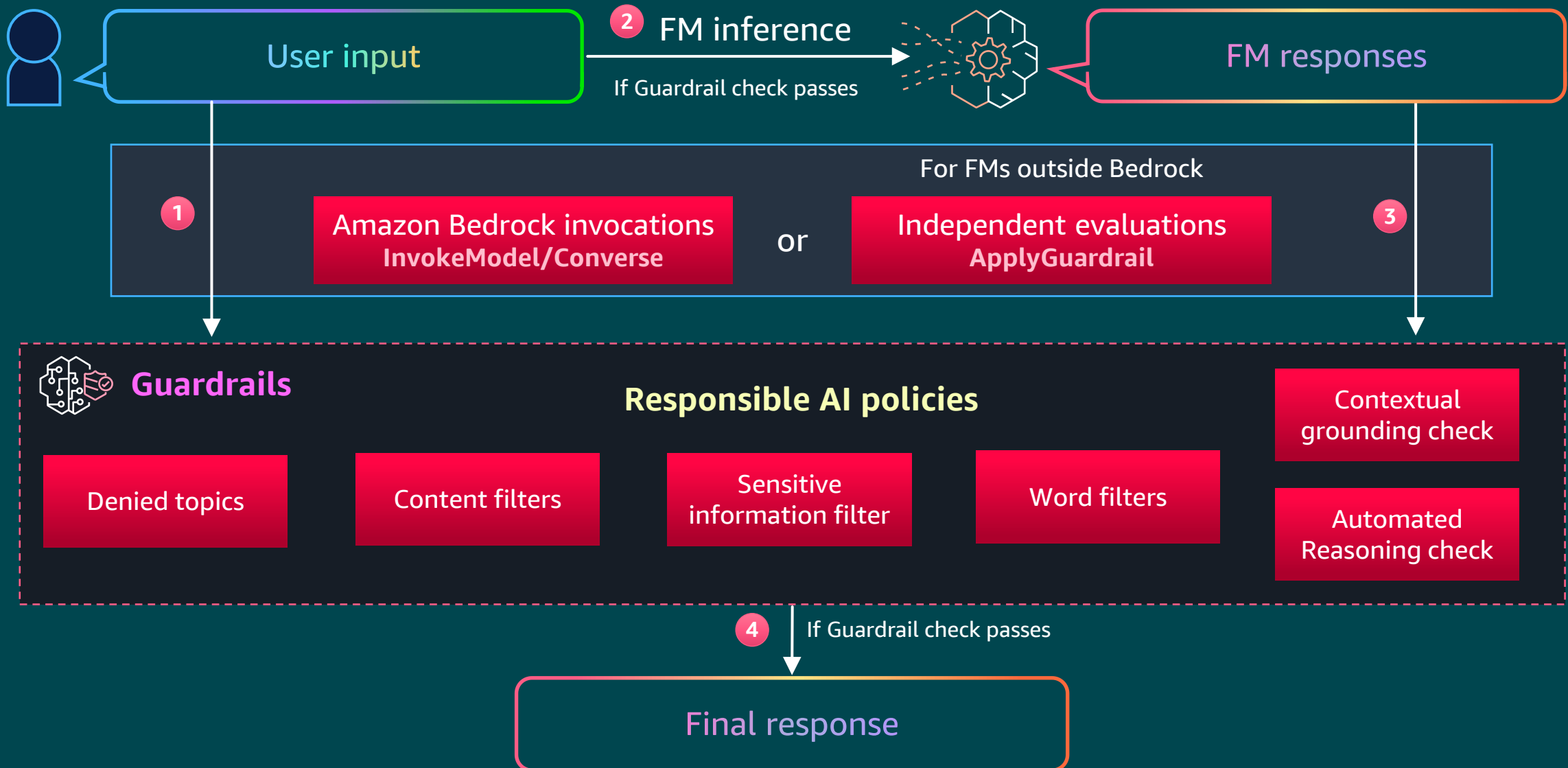
Governance Need	AWS Control
Allow only approved models	IAM policies scoped to specific Bedrock model ARNs
Enforce across many AWS accounts	Service Control Policies (SCPs)
Block a specific model	Deny bedrock:InvokeModel / InvokeModelWithResponseStream
Restrict Marketplace model subscriptions	aws-marketplace:ProductId conditions
Require an approved guardrail during inference	bedrock:GuardrailIdentifier condition key

How Do We Keep Agent Interactions Within Safe Boundaries?

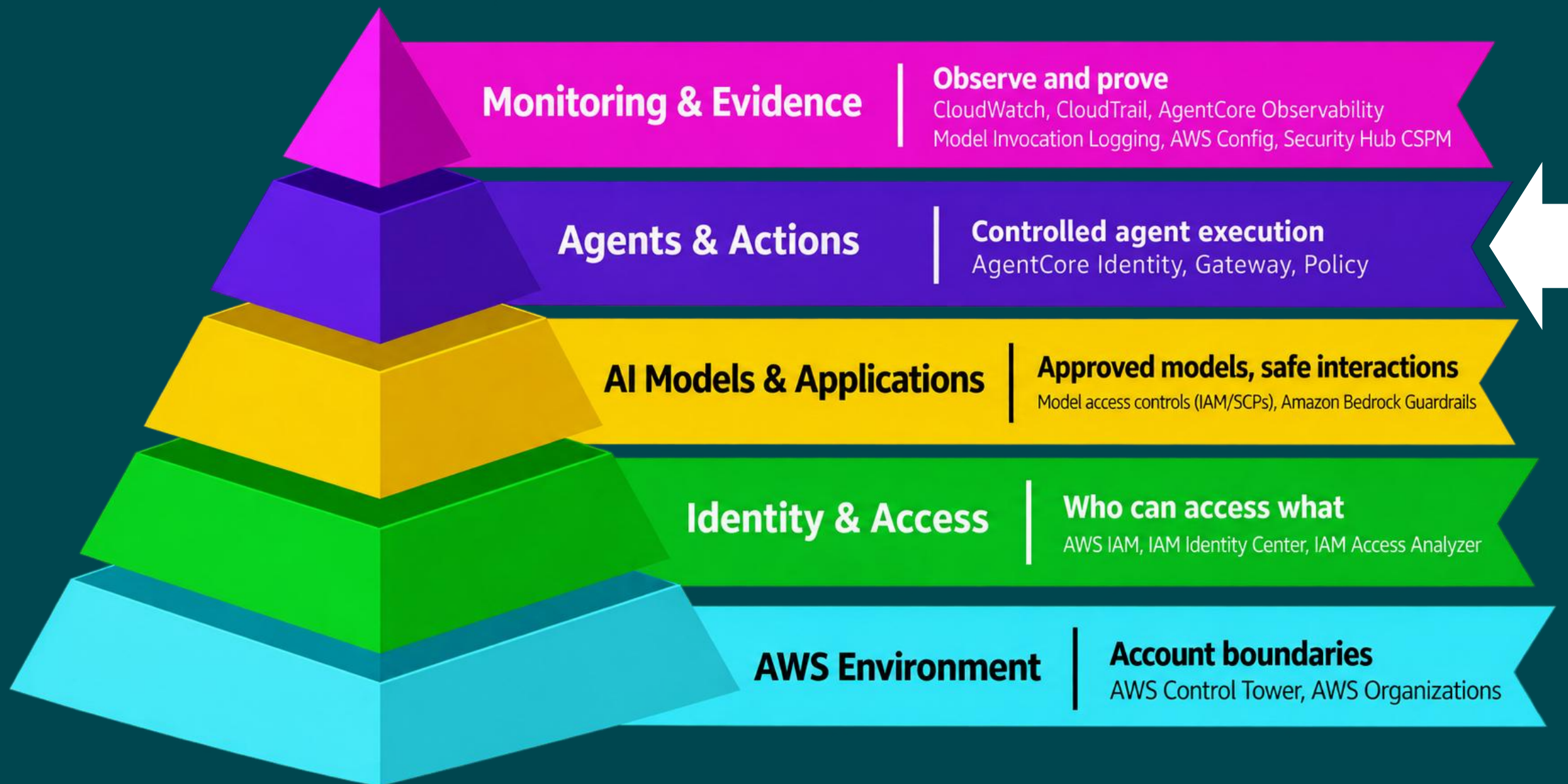
- Even when developers use an approved model, an agent can still receive unsafe instructions or generate responses that violate safety, privacy, content, or grounding policies.
- We need Guardrails



Amazon Bedrock Guardrails



AI Governance in AWS





Agents
&
Actions

How Does an AI Agent Get Its Own Identity?

- AI agents need a distinct identity so every action can be tied to which agent acted, on whose behalf, and with what permissions.
- A static IAM role usually represents only the workload, but agents often act for different users and across multiple trust domains, so authorization may need both agent identity + user context rather than a single fixed role.

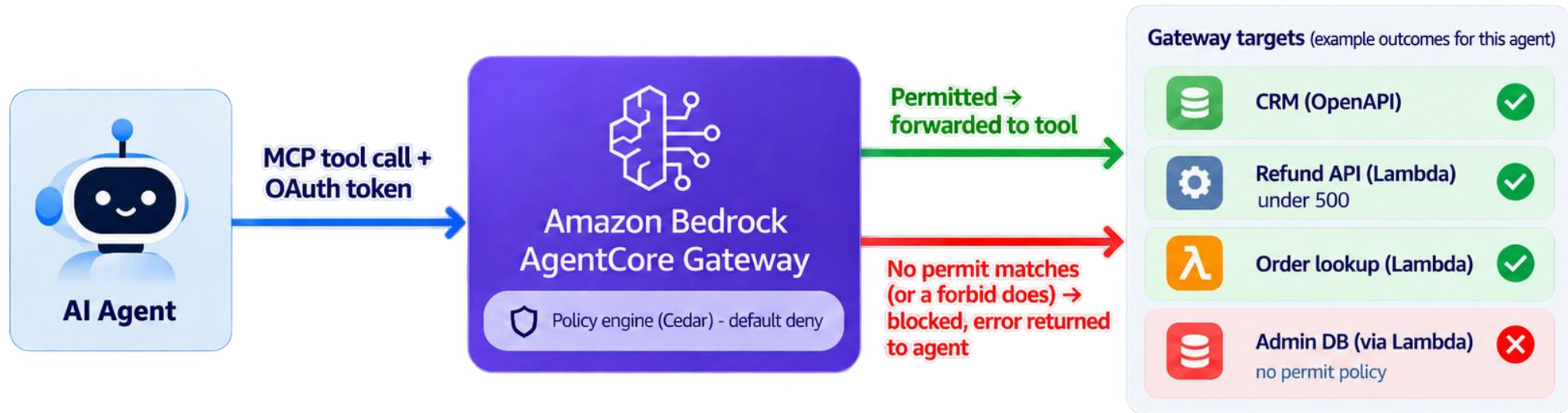
Business Need	AgentCore Identity Capability
Manage identities centrally	Agent Identity Directory
Access AWS resources	IAM / SigV4 integration
Access external services	OAuth 2.0 / API keys
Secure credentials	Credential providers / Token Vault

How Do We Control Which Tools an Agent Can Reach?

- An AI agent may need to interact with many enterprise systems:
CRM • Refund API • Lambda • Database • SaaS tools
- Giving the agent direct access to every backend creates governance risk.

Governance Need	AgentCore Gateway Capability
Centralize tool access	Single gateway endpoint
Expose only approved tools	Gateway targets
Authenticate incoming agent requests	Inbound authorization
Secure access to backend tools	Outbound authorization
Standardize tool access	MCP interface

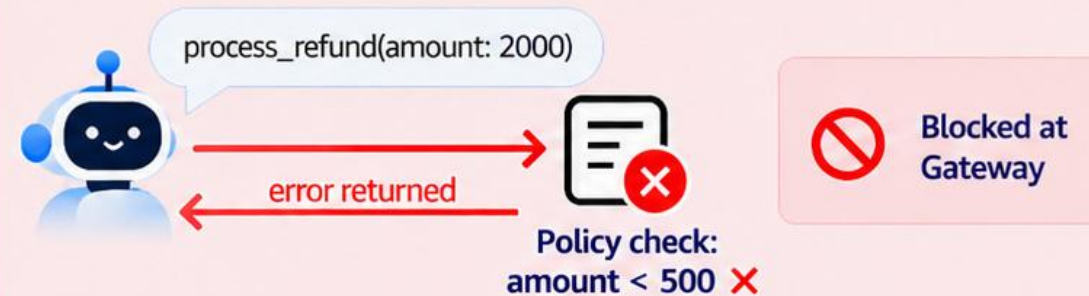
How Do We Restrict What An Agent Can Do Through a Tool?



Allowed request (amount within limit)



Denied request (amount exceeds limit)

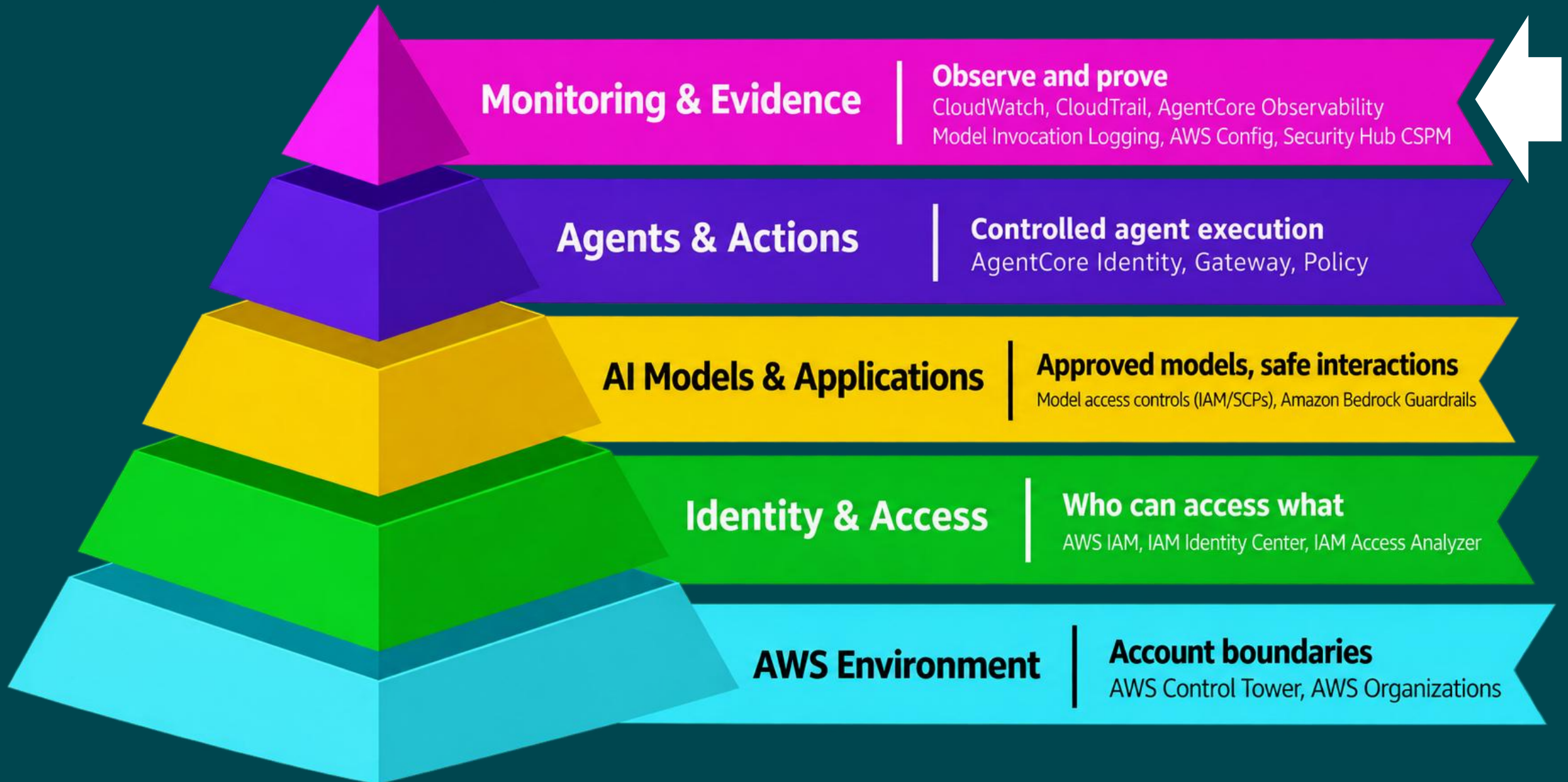


i Policies can also check who is calling, e.g. users with a finance role get a higher refund limit.

(simplified)

```
permit(principal, action == Action::"process_refund", resource)
when { context.input.amount < 500 };
```

AI Governance in AWS





Monitoring & Evidence

What Is the Agent Doing in Production?

- Governance does not stop when the agent is deployed. You need visibility into every important action it takes.

Amazon Bedrock AgentCore Observability

Agent-specific observability for sessions, traces, spans, tool execution, performance and errors.

Amazon CloudWatch GenAI Observability

Central dashboards and views for GenAI resources, agents, traces, logs, metrics and troubleshooting.

Third Party Observability Tools



And many more...

And many more...

Who Did What and What Happened?

- CloudTrail tells you who did what in AWS. Model Invocation Logging tells you what happened inside the model interaction.

Question	AWS Service
Who called which AWS API?	AWS CloudTrail
When and from where?	
Which model was invoked?	Bedrock Model Invocation Logging
What input was sent?	
What output was returned?	

How Do We Continuously Assess Compliance?

- AWS Config: Continuously tracks configuration and evaluates compliance



Example: EBS Volume Encryption



Example: AI Agent IAM Policy



Requires supported IAM policy recording.

Can we show evidence that those controls are working?

- AWS Config conformance packs continuously check your controls and give auditors evidence that they are working.

What auditors may ask for



Approved model



Access controls



Guardrail settings



Agent actions



Monitoring logs



Conformance Pack
e.g. Security and Governance Best Practices for AI/ML Supporting Infrastructure



AWS Config Evaluates
Config rules check each resource



Compliance Dashboard
Score, timeline, per-resource status



Export Evidence
Advanced Query, config history, Athena



Auditor
Reviews evidence

Additional evidence for a complete view



CloudTrail – API activity



Model Invocation Logging – prompts & responses



AgentCore Observability – agent actions



From Workshop
to
Action

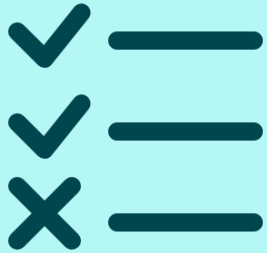


Hands-on Workshop

Walkthrough

Next Steps: Your Turn to Act

1



Complete the
Knowledge
Check

2



Practice the
Hands-on
Workshop

3



Be active and
Support
Your Peers

4



Share Your
Learning on
Social Media

Beyond The Batch

- Quiz will be open till Oct-31
- Certificate will be automatically assigned after completion of 6 quizzes
- Batch 10 will be launched in Self-paced fashion
- Meet BeSA team at Re:Invent
- Share your feedback / suggestions / appreciation
- Packt Access – They are resolving issue
- Next Batch – Probably Feb 2027